

Supplier Due Diligence File

Metadata	Value
Document ID	[GRC-EVD-SUP-001]
Version	1.0
Owner	[Procurement / Vendor Risk Owner]
Effective Date	[YYYY-MM-DD]
Framework	ISO/IEC 27001:2022
Classification	Confidential

Purpose

The purpose of this Supplier Due Diligence File is to provide auditable evidence that [Organisation Name] has assessed, approved, and documented information security risks associated with each supplier relationship in accordance with ISO/IEC 27001:2022 Annex A.5.19.

This evidence file demonstrates that supplier-related information security requirements are identified and addressed before engagement, during onboarding, and throughout the supplier lifecycle, based on the supplier's access to information assets, systems, facilities, services, or business processes.

This document is intended to be maintained as a per-supplier evidence record and used to support internal governance, supplier risk management, management review, internal audit, external certification audit, and regulatory or customer assurance activities.

What This Evidence Demonstrates

This evidence demonstrates that [Organisation Name] has performed appropriate supplier information security due diligence before entering into or materially changing a supplier relationship.

For each supplier, the evidence file demonstrates that:

Evidence Objective	Demonstrated By	ISO/IEC 27001:2022 Relevance
The supplier relationship has been identified and recorded	Supplier profile, business owner, service description, contract reference, onboarding date	Confirms the organisation understands the supplier relationship and its context
Information security risks associated with the supplier have been assessed	Supplier risk assessment, inherent risk rating, data classification, access profile, criticality assessment	Supports identification and treatment of supplier-related risks
Information security requirements have been defined for the supplier	Contractual clauses, security schedules, data protection terms, service-level requirements	Supports establishment of security requirements in supplier relationships
Due diligence has been performed proportionate to supplier risk	Security questionnaire, certifications, audit reports, penetration test summaries, policies, compliance attestations	Demonstrates risk-based validation of supplier security posture
Supplier access to information and systems has been reviewed	Access scope, privileged access status, connectivity details, authentication requirements	Supports protection of organisational assets accessible to suppliers
Legal, regulatory, and contractual obligations have been considered	Data processing agreement, confidentiality terms, regulatory applicability assessment	Demonstrates supplier obligations are aligned with organisational requirements
Risks, exceptions, and remediation actions have been recorded	Risk treatment plan, exceptions register, compensating controls, remediation due dates	Demonstrates governance and control over supplier-related security gaps
Supplier approval was formally obtained	Approval record from business owner, information security, legal, procurement, and privacy where applicable	Confirms accountable decision-making before supplier engagement
Ongoing monitoring requirements have been defined	Review frequency, assurance refresh cycle, performance/security monitoring criteria	Supports continued management of supplier security risks
Evidence is retained and access-controlled	Evidence repository record, retention period, access permissions	Supports integrity, confidentiality, and auditability of due diligence records

This evidence supports the conclusion that supplier relationships are subject to appropriate information security governance and that risks arising from supplier access to [Organisation Name] information assets are managed

through defined requirements, assessment, approval, and monitoring.

Scope

This Supplier Due Diligence File applies to each external supplier, vendor, service provider, contractor organisation, outsourcing provider, professional services provider, cloud service provider, managed service provider, software-as-a-service provider, data processor, hosting provider, facilities provider, or other third party that may:

- Access, process, store, transmit, or manage [Organisation Name] information;
- Access [Organisation Name] information systems, networks, applications, premises, or operational environments;
- Provide technology, infrastructure, security, business process, or operational services;
- Support critical or important business activities;
- Process personal data, confidential information, regulated information, intellectual property, authentication credentials, logs, telemetry, or customer information;
- Have privileged, remote, administrative, integration, or API-based access;
- Provide services that affect the confidentiality, integrity, availability, privacy, or resilience of [Organisation Name] information or services.

This evidence file shall be completed for each supplier where information security risk exists. The level of due diligence shall be proportionate to the supplier risk classification.

Supplier Risk Classification

Risk Tier	Typical Supplier Characteristics	Minimum Due Diligence Expected	Review Frequency
Critical	Supports critical business service; stores or processes highly confidential or regulated data; has privileged or persistent access; provides core infrastructure, cloud, managed security, identity, or production services	Full security questionnaire, independent assurance report where available, contractual security schedule, data protection review, business continuity review, risk approval, executive or delegated risk owner approval	At least annually
High	Processes confidential or personal data; integrates with internal systems; supports important business process; has remote or API access	Security questionnaire, evidence of security controls, contractual security requirements, privacy/legal review where applicable, risk owner approval	At least annually or every 18 months
Medium	Limited access to internal information; no privileged access; limited operational dependency; standard commercial SaaS with moderate data sensitivity	Targeted questionnaire, security documentation review, standard security clauses, business owner approval	At least every 24 months
Low	No access to confidential information, systems, or personal data; minimal information security impact	Supplier profile, business justification, basic confidentiality and acceptable use terms where applicable	At renewal or material change

Triggers for Creating or Updating the File

A Supplier Due Diligence File shall be created or updated when:

- A new supplier is proposed for onboarding;
- The supplier will access new information, systems, data types, or environments;
- The scope of services materially changes;

- The supplier's ownership, location, hosting model, subcontracting model, or security posture changes materially;
- A contract is renewed or extended;
- A significant security incident, breach, regulatory issue, or service failure involving the supplier occurs;
- New legal, regulatory, customer, or contractual obligations affect the supplier relationship;
- Periodic reassessment becomes due according to the supplier risk tier.

Required Contents

Each Supplier Due Diligence File shall contain sufficient evidence to demonstrate a complete and risk-based assessment of the supplier relationship. The following contents are required unless explicitly marked as not applicable with documented justification.

1. Supplier Profile

Field	Required Information
Supplier legal name	[Supplier Legal Name]
Supplier trading name	[Supplier Trading Name, if applicable]
Supplier website	[Supplier URL]
Supplier headquarters location	[Country / Region]
Primary service or product	[Description of service or product]
Business owner	[Business Owner Name / Role]
Procurement owner	[Procurement Owner Name / Role]
Information security reviewer	[Security Reviewer Name / Role]
Privacy reviewer, if applicable	[Privacy Reviewer Name / Role]
Legal reviewer, if applicable	[Legal Reviewer Name / Role]
Contract reference	[Contract ID / Agreement Name]
Engagement start date	[YYYY-MM-DD]
Renewal or review date	[YYYY-MM-DD]
Supplier status	Proposed / Approved / Approved with Conditions / Rejected / Offboarding

2. Service and Information Flow Description

The file shall describe the supplier service and the information security relevance of the engagement.

Area	Description
Business purpose	[Description of why the supplier is required]
Service provided	[Description of supplier service]
Systems involved	[Applications, platforms, infrastructure, APIs, integrations]
Information exchanged	[Types of information shared with or accessible to supplier]
Data classification	Public / Internal / Confidential / Restricted / [Organisation-specific classification]
Personal data involved	Yes / No
Regulated data involved	Yes / No; specify type if applicable
Data processing location(s)	[Countries / Regions]
Hosting model	On-premises / Supplier-hosted / Cloud / SaaS / Managed service / Hybrid
Integration method	Manual transfer / SFTP / API / VPN / Direct network connection / SSO / Other
Supplier access type	No access / User access / Administrative access / Privileged access / Break-glass access
Subcontractors involved	Yes / No / Unknown; list if known

Area	Description
Business criticality	Critical / High / Medium / Low

3. Supplier Inherent Risk Assessment

The file shall include an inherent risk assessment completed before supplier approval.

Risk Factor	Assessment Criteria	Rating
Data sensitivity	Highest classification of information accessed, processed, stored, or transmitted by supplier	Low / Medium / High / Critical
Personal or regulated data	Involvement of personal data, financial data, health data, payment data, customer data, export-controlled data, or other regulated information	Low / Medium / High / Critical
System access	Level of logical access to organisational systems, networks, applications, APIs, or identity services	Low / Medium / High / Critical
Privileged access	Whether supplier has administrative, root, domain, production, security tooling, or elevated access	Low / Medium / High / Critical
Availability dependency	Impact on business operations if supplier service is unavailable	Low / Medium / High / Critical
Integrity dependency	Impact if supplier data, software, configuration, or service output is inaccurate or unauthorisedly modified	Low / Medium / High / Critical
External connectivity	Nature of technical integration or network connectivity with supplier	Low / Medium / High / Critical
Subcontracting risk	Use of fourth parties or downstream service providers affecting service delivery or data handling	Low / Medium / High / Critical
Geographic/legal exposure	Countries involved in processing, support, hosting, or remote access	Low / Medium / High / Critical
Incident history or reputation	Known breaches, unresolved audit findings, regulatory sanctions, or adverse public reporting	Low / Medium / High / Critical
Overall inherent risk tier	Highest relevant risk rating adjusted by business criticality and compensating factors	Critical / High / Medium / Low

4. Due Diligence Evidence Index

The file shall include an index of all evidence collected and reviewed.

Evidence Item	Required For	Document / Source	Date Received	Reviewer	Outcome
Completed supplier security questionnaire	Medium, High, Critical	[Questionnaire File / System Record]	[YYYY-MM-DD]	[Reviewer]	Accepted / Follow-up Required / Rejected
ISO/IEC 27001 certificate or equivalent assurance	High, Critical where available	[Certificate Reference]	[YYYY-MM-DD]	[Reviewer]	Valid / Expired / Not Provided / Not Applicable
SOC 2 Type II report or equivalent independent audit report	High, Critical SaaS/cloud/managed service suppliers where available	[Report Reference]	[YYYY-MM-DD]	[Reviewer]	Accepted / Exceptions Noted / Not Provided
Information security policy summary	Medium, High, Critical	[Document Reference]	[YYYY-MM-DD]	[Reviewer]	Accepted / Follow-up Required
Access control and identity management evidence	High, Critical or where system access is provided	[Document Reference]	[YYYY-MM-DD]	[Reviewer]	Accepted / Follow-up Required
Encryption and key management evidence	Where confidential, restricted, personal, or regulated data is processed	[Document Reference]	[YYYY-MM-DD]	[Reviewer]	Accepted / Follow-up Required
Vulnerability management evidence	High, Critical technology suppliers	[Document Reference]	[YYYY-MM-DD]	[Reviewer]	Accepted / Follow-up Required
Secure development evidence	Software, SaaS, API, or development suppliers	[Document Reference]	[YYYY-MM-DD]	[Reviewer]	Accepted / Follow-up Required

Evidence Item	Required For	Document / Source	Date Received	Reviewer	Outcome
Incident management process	Medium, High, Critical	[Document Reference]	[YYYY-MM-DD]	[Reviewer]	Accepted / Follow-up Required
Business continuity and disaster recovery evidence	High, Critical or availability-dependent services	[Document Reference]	[YYYY-MM-DD]	[Reviewer]	Accepted / Follow-up Required
Data protection agreement or data processing addendum	Where personal data is processed	[Agreement Reference]	[YYYY-MM-DD]	[Reviewer]	Executed / Pending / Not Applicable
Subprocessor or subcontractor list	Where subcontractors are used	[List Reference]	[YYYY-MM-DD]	[Reviewer]	Accepted / Follow-up Required
Penetration test executive summary	Critical or internet-facing SaaS/application suppliers where available	[Report Reference]	[YYYY-MM-DD]	[Reviewer]	Accepted / Exceptions Noted / Not Provided
Contract security schedule	Medium, High, Critical	[Contract Schedule Reference]	[YYYY-MM-DD]	[Reviewer]	Executed / Pending / Not Applicable
Risk treatment or remediation plan	Where gaps or exceptions are identified	[Risk Record Reference]	[YYYY-MM-DD]	[Reviewer]	Open / In Progress / Closed

5. Control Areas Reviewed

The due diligence file shall document the supplier's security posture across control areas relevant to Annex A.5.19 and the specific supplier service.

Control Area	Review Considerations	Result
Governance and security management	Supplier has defined information security governance, roles, policies, and management oversight	Satisfactory / Gap Identified / Not Applicable
Asset and information handling	Supplier classifies, handles, stores, transmits, and disposes of information appropriately	Satisfactory / Gap Identified / Not Applicable
Access control	Supplier enforces least privilege, unique user IDs, authentication, access reviews, and termination controls	Satisfactory / Gap Identified / Not Applicable
Privileged access management	Supplier controls administrative access, logging, approval, and separation of duties	Satisfactory / Gap Identified / Not Applicable
Cryptography	Data is encrypted in transit and at rest where required; key management responsibilities are defined	Satisfactory / Gap Identified / Not Applicable
Operations security	Supplier performs logging, monitoring, malware protection, backup, hardening, and change control	Satisfactory / Gap Identified / Not Applicable
Vulnerability and patch management	Supplier identifies, prioritises, remediates, and reports vulnerabilities within defined timeframes	Satisfactory / Gap Identified / Not Applicable
Secure development	Supplier applies secure SDLC, code review, testing, dependency management, and release control where applicable	Satisfactory / Gap Identified / Not Applicable
Incident management	Supplier has incident detection, response, escalation, notification, and evidence preservation processes	Satisfactory / Gap Identified / Not Applicable
Business continuity	Supplier maintains business continuity and disaster recovery capabilities aligned to service criticality	Satisfactory / Gap Identified / Not Applicable
Physical and environmental security	Supplier protects facilities, data centres, and workspaces where relevant	Satisfactory / Gap Identified / Not Applicable
Human resources security	Supplier performs screening, confidentiality commitments, security awareness, and role-based training where relevant	Satisfactory / Gap Identified / Not Applicable
Data protection and privacy	Supplier meets applicable personal data processing, data subject rights, retention, transfer, and breach notification requirements	Satisfactory / Gap Identified / Not Applicable
Subcontractor management	Supplier manages downstream providers and flows down security obligations	Satisfactory / Gap Identified / Not Applicable

Control Area	Review Considerations	Result
Audit and assurance rights	Contract or assurance materials provide adequate visibility over supplier security controls	Satisfactory / Gap Identified / Not Applicable
Exit and return/destruction	Supplier can return, delete, destroy, or securely transition information upon termination	Satisfactory / Gap Identified / Not Applicable

6. Contractual Security Requirements

The evidence file shall confirm that applicable information security requirements have been incorporated into the supplier agreement or associated schedules.

Contractual Requirement	Required Where Applicable	Evidence / Clause Reference	Status
Confidentiality obligations	All suppliers with access to non-public information	[Clause Reference]	Included / Not Included / Not Applicable
Information security requirements	Medium, High, Critical suppliers	[Clause Reference]	Included / Not Included / Not Applicable
Acceptable use and access restrictions	Suppliers with system or information access	[Clause Reference]	Included / Not Included / Not Applicable
Data protection and privacy obligations	Suppliers processing personal data	[Clause Reference]	Included / Not Included / Not Applicable
Incident notification timeframe	Suppliers processing confidential, personal, or regulated data or supporting important services	[Clause Reference]	Included / Not Included / Not Applicable
Breach cooperation and investigation support	Suppliers with security or data exposure risk	[Clause Reference]	Included / Not Included / Not Applicable
Vulnerability remediation expectations	Technology, SaaS, cloud, software, managed service suppliers	[Clause Reference]	Included / Not Included / Not Applicable
Right to audit or obtain assurance evidence	High and Critical suppliers	[Clause Reference]	Included / Not Included / Not Applicable
Subcontractor approval or notification	Suppliers using subcontractors for service delivery or data processing	[Clause Reference]	Included / Not Included / Not Applicable
Data location and transfer restrictions	Suppliers processing regulated, personal, or restricted information	[Clause Reference]	Included / Not Included / Not Applicable
Business continuity and disaster recovery commitments	High and Critical suppliers	[Clause Reference]	Included / Not Included / Not Applicable
Secure deletion, return, or transition support	Suppliers handling organisational information	[Clause Reference]	Included / Not Included / Not Applicable
Compliance with applicable laws and regulations	All relevant suppliers	[Clause Reference]	Included / Not Included / Not Applicable
Security monitoring, reporting, or service-level commitments	Where required by service criticality	[Clause Reference]	Included / Not Included / Not Applicable

7. Identified Risks, Gaps, and Exceptions

All identified supplier security risks, due diligence gaps, and exceptions shall be recorded and tracked to closure or formally accepted.

Risk / Gap ID	Description	Impact	Risk Rating	Required Action	Owner	Due Date	Status
[SUP-RISK-001]	[Description of identified risk or evidence gap]	[Potential impact to confidentiality, integrity, availability, privacy, or compliance]	Critical / High / Medium / Low	[Remediation, compensating control, contractual requirement, risk acceptance]	[Owner]	[YYYY-MM-DD]	Open / In Progress / Accepted / Closed

Where a risk is accepted, the evidence file shall include:

- Risk acceptance rationale;
- Name and role of the approving risk owner;

- Approval date;
- Expiry or review date of the acceptance;
- Compensating controls, if any;
- Monitoring requirements.

8. Supplier Approval Record

The file shall include documented approval before contract execution, service activation, production access, or transfer of confidential, restricted, personal, or regulated information, unless an approved exception exists.

Approval Role	Name / Role	Approval Decision	Date	Comments
Business owner	[Name / Role]	Approved / Approved with Conditions / Rejected	[YYYY-MM-DD]	[Comments]
Procurement owner	[Name / Role]	Approved / Approved with Conditions / Rejected	[YYYY-MM-DD]	[Comments]
Information security	[Name / Role]	Approved / Approved with Conditions / Rejected	[YYYY-MM-DD]	[Comments]
Privacy / data protection, if applicable	[Name / Role]	Approved / Approved with Conditions / Rejected / Not Applicable	[YYYY-MM-DD]	[Comments]
Legal, if applicable	[Name / Role]	Approved / Approved with Conditions / Rejected / Not Applicable	[YYYY-MM-DD]	[Comments]
Risk owner, if required	[Name / Role]	Approved / Approved with Conditions / Rejected / Not Applicable	[YYYY-MM-DD]	[Comments]

Approval with conditions shall not permit unrestricted supplier use until the stated conditions, compensating controls, or risk acceptances are documented and approved.

9. Ongoing Monitoring Requirements

The evidence file shall define ongoing monitoring requirements proportionate to the supplier's risk tier.

Monitoring Activity	Applies To	Frequency	Evidence Required
Supplier risk reassessment	All suppliers with security relevance	Based on risk tier	Updated supplier risk assessment
Security questionnaire refresh	Medium, High, Critical suppliers	Based on risk tier or material change	Updated questionnaire and review notes
Independent assurance review	High and Critical suppliers where available	Annually or upon report expiry	Current certification, SOC report, audit report, or equivalent
Contractual security requirement review	Medium, High, Critical suppliers	At renewal or material change	Contract review notes and clause confirmation
Access review	Suppliers with logical access	At least annually; more frequently for privileged access	Access review evidence and remediation records
Subcontractor review	Suppliers using subcontractors	At reassessment or notification of change	Updated subprocessor/subcontractor list
Incident and breach review	Suppliers with reported incidents or known security events	Event-driven	Incident report, corrective action plan, risk review
Performance and availability review	High and Critical operational suppliers	As defined by service criticality	Service reports, SLA reports, continuity test evidence
Remediation tracking	Suppliers with open gaps	Until closure	Remediation plan, status updates, closure evidence

Collection & Validation

Supplier due diligence evidence shall be collected, reviewed, validated, and approved in a controlled manner to ensure the evidence is reliable, complete, current, and attributable.

Collection Requirements

Evidence shall be collected from authoritative sources, such as:

- Supplier-provided security questionnaire responses;
- Supplier trust portal documentation;
- Executed contracts and security schedules;
- Independent audit reports, including ISO/IEC 27001 certificates, SOC 2 reports, or equivalent assurance reports;
- Data processing agreements, subprocessor lists, and privacy documentation;
- Security policies, standards, architecture summaries, and control descriptions;
- Business continuity and disaster recovery summaries;
- Vulnerability management and penetration testing summaries;
- Incident management procedures and notification commitments;
- Internal procurement, legal, privacy, security, and risk management systems;
- Access management and identity governance records;
- Risk registers and exception approval records.

Evidence shall be obtained before supplier approval wherever practicable. Where evidence cannot be obtained before engagement due to urgent business need, an exception shall be recorded, approved by the appropriate risk owner, time-bound, and subject to compensating controls.

Validation Criteria

The reviewer shall validate the evidence against the following criteria:

Validation Criterion	Requirement
Completeness	Evidence addresses all required due diligence areas for the supplier risk tier
Currency	Evidence is current or within the acceptable review period; expired certifications or reports are not accepted without justification
Authenticity	Evidence originates from the supplier, an independent assessor, an executed agreement, or an approved internal system
Relevance	Evidence applies to the specific service, legal entity, environment, region, and data flow being assessed
Consistency	Supplier responses align with contracts, assurance reports, technical architecture, and known service characteristics
Sufficiency	Evidence provides enough detail to determine whether supplier risks are acceptable or require treatment
Traceability	Evidence is linked to supplier name, contract, review date, reviewer, and approval decision
Confidentiality	Sensitive supplier reports and security information are protected according to classification requirements

Review Method

The information security reviewer shall:

- Confirm the supplier profile and service description are complete.
- Determine the supplier’s inherent risk tier.
- Identify the information types, access methods, hosting arrangements, integrations, and business dependencies.
- Select due diligence evidence requirements based on the supplier risk tier and service characteristics.
- Review collected evidence against applicable security requirements.
- Identify control gaps, unresolved questions, and contractual security requirements.
- Record risks, remediation actions, exceptions, or required compensating controls.
- Confirm whether legal, privacy, procurement, business continuity, or technology architecture review is required.
- Document the approval recommendation.
- Obtain required approvals before onboarding, service activation, access provisioning, or data transfer.

Evidence Quality Rating

Each file should include an evidence quality rating to support audit reliance.

Evidence Quality Rating	Criteria	Auditor Reliance
Strong	Current, independently validated where appropriate, complete, service-specific, traceable, and supported by executed contractual requirements	High
Adequate	Current and generally complete, but relies partly on supplier self-attestation or standard documentation	Moderate
Limited	Incomplete, outdated, generic, not service-specific, or unsupported by contractual commitments	Low
Insufficient	Missing key evidence, unresolved high-risk gaps, or inconsistent supplier information	Not suitable without remediation or risk acceptance

Sample Validation Record

Validation Item	Result
Supplier assessed	[Supplier Legal Name]
Assessment date	[YYYY-MM-DD]
Supplier risk tier	Critical / High / Medium / Low
Evidence quality rating	Strong / Adequate / Limited / Insufficient
Key evidence reviewed	[List key evidence references]
Material gaps identified	Yes / No
Open risk records	[Risk IDs or None]
Contract security clauses verified	Yes / No / Not Applicable
Privacy review required	Yes / No
Business continuity review required	Yes / No
Final security recommendation	Approve / Approve with Conditions / Reject / Defer
Reviewer	[Name / Role]

Retention & Access

Supplier Due Diligence Files shall be retained and protected to preserve confidentiality, integrity, availability, and auditability of supplier risk management evidence.

Retention Requirements

Record Type	Minimum Retention Period	Retention Trigger
Supplier due diligence file	Duration of supplier relationship plus [X] years	Supplier termination or contract expiry
Supplier risk assessment	Duration of supplier relationship plus [X] years	Supersession, termination, or contract expiry
Security questionnaires and supplier responses	Duration of supplier relationship plus [X] years	Supersession or termination
Independent assurance reports and certifications	Duration of supplier relationship plus [X] years	Report expiry, supersession, or termination
Contractual security schedules and data protection agreements	Duration of contract plus [X] years	Contract expiry or termination
Risk acceptances and exceptions	Duration of acceptance plus [X] years or supplier relationship plus [X] years, whichever is longer	Expiry, closure, or termination
Remediation and closure evidence	Duration of supplier relationship plus [X] years	Closure or termination
Approval records	Duration of supplier relationship plus [X] years	Supplier termination or contract expiry
Access review evidence for supplier accounts	In accordance with access management retention requirements, minimum [X] years	Completion of access review

Retention periods shall align with [Organisation Name]'s records retention schedule, contractual obligations, regulatory requirements, and litigation hold requirements. Where multiple retention obligations apply, the longest applicable period shall be used.

Storage Location

Supplier due diligence evidence shall be stored in an approved controlled repository, such as:

Evidence Repository	Use	Access Control Requirement
[GRC Platform]	Risk assessments, approval records, exceptions, review schedules	Role-based access restricted to authorised governance, risk, procurement, security, and audit personnel
[Contract Management System]	Executed agreements, security schedules, data protection agreements	Restricted to procurement, legal, contract owners, and authorised reviewers
[Document Management System]	Supplier questionnaires, assurance reports, supporting documents	Confidential workspace with access logging and version control
[Identity Governance System]	Supplier access reviews and access approval evidence	Restricted to identity, security, system owners, and auditors as required

Evidence shall not be stored in personal drives, unmanaged email folders, local desktops, or unauthorised collaboration spaces.

Access Requirements

Access to Supplier Due Diligence Files shall be granted on a need-to-know basis. At minimum:

- Information security reviewers may access supplier security evidence relevant to assessments.
- Procurement and vendor management personnel may access supplier profile, contract, and onboarding evidence.
- Legal personnel may access contractual and regulatory documentation.
- Privacy personnel may access data processing and privacy-related evidence.
- Business owners may access supplier risk status and required remediation actions.
- Internal auditors and external auditors may access evidence required to verify operation of ISO/IEC 27001:2022 Annex A.5.19 controls.

- Supplier-provided confidential assurance reports shall be accessed only by authorised personnel and handled according to any supplier-imposed confidentiality conditions.

Protection Requirements

Supplier Due Diligence Files shall be protected as Confidential unless a higher classification is required due to the sensitivity of contained information.

The following protection measures shall apply:

- Role-based access control;
- Multi-factor authentication for repositories containing confidential supplier evidence;
- Version control and change history;
- Audit logging of access and modifications;
- Encryption in transit and at rest;
- Restrictions on external sharing;
- Watermarking or download restrictions for highly sensitive supplier assurance reports where supported;
- Secure deletion at the end of the retention period;
- Immediate access revocation when personnel no longer require access;
- Litigation hold preservation where instructed by legal counsel.

Audit Readiness

The Supplier Due Diligence File shall be maintained in a condition suitable for audit review. For each supplier sampled by an auditor, [Organisation Name] shall be able to demonstrate:

- Supplier risk classification was completed;
- Due diligence evidence was collected proportionate to risk;
- Security requirements were defined and contractually addressed where applicable;
- Identified risks and exceptions were tracked and approved;
- Supplier approval occurred before onboarding or was covered by an approved exception;
- Ongoing monitoring requirements were defined and followed;
- Evidence was retained in a controlled repository with appropriate access restrictions.